

Week 3 Security Audit

Basic Security Audit of a Sample Website

Target: OWASP Juice Shop • URL: http://localhost:3000
Tool: OWASP ZAP 2.17.0 • Report date: 21 September 2026

0 HIGH	2 MEDIUM	1 LOW	1 INFO
-----------	-------------	----------	-----------

1. Executive Summary

A security audit was performed against a locally hosted OWASP Juice Shop instance. The application was assessed using OWASP ZAP, with the scan output retained as supporting evidence (`evidence/zap-report.html` and `evidence/zap-report.pdf`).

The ZAP report contains **four alert types**: two medium-risk alerts (CSP Header Not Set, Cross-Domain/CORS Misconfiguration), one low-risk alert (Unix Timestamp Disclosure), and one informational alert (Modern Web Application).

The audit documents three practical vulnerability areas, spanning three distinct OWASP Top 10 categories:

1. Security Misconfiguration — missing Content Security Policy header
2. Broken Access Control — permissive CORS policy
3. Information Disclosure — Unix timestamps exposed in static responses

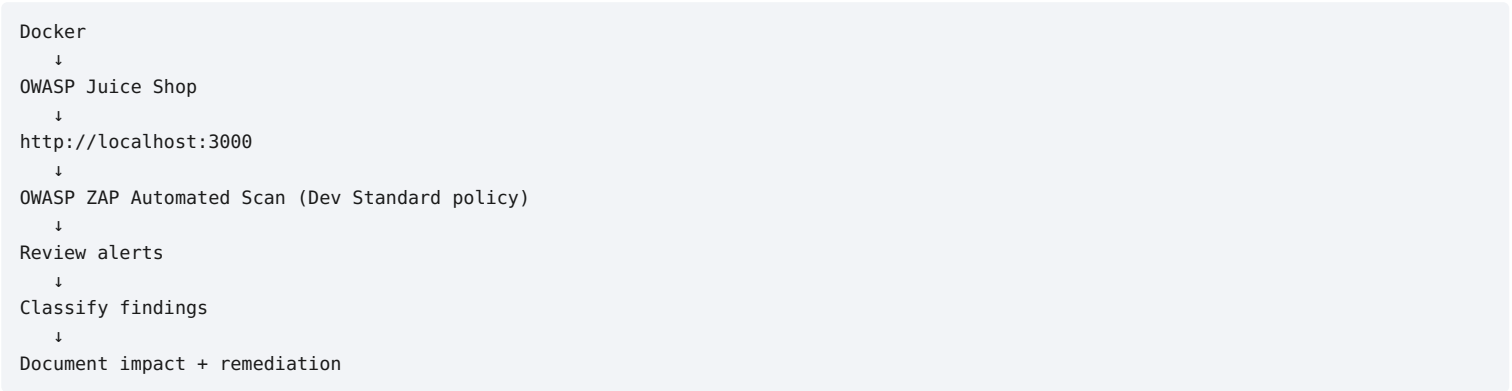
The informational "Modern Web Application" alert is not treated as a vulnerability, since ZAP explicitly classifies it as informational and states no changes are required.

2. Methodology

The assessment followed the Week 3 task requirements:

1. Use a legal practice target.
2. Run OWASP Juice Shop locally.
3. Use OWASP ZAP to assist the audit.
4. Review the generated findings.
5. Document each finding, discovery method, category, impact, and remediation.
6. Preserve the ZAP report as evidence.

Testing workflow



3. Findings

Finding 1 — Content Security Policy (CSP) Header Not Set

Severity: Medium
ZAP confidence: High
OWASP category: Security Misconfiguration — OWASP Top 10 2021 A05
CWE: CWE-693 | **WASC:** 15 | **ZAP Plugin ID:** 10038
Instances: 5 (systemic), including `/` , `/ftp` , `/ftp/coupons_2013.md.bak` , `/ftp/package-lock.json.bak` , `/sitemap.xml`

What was found

ZAP's passive scanner reported "**Content Security Policy (CSP) Header Not Set**" across multiple endpoints. None of the affected responses included a `Content-Security-Policy` header at all.

Steps taken to find it

1. Started the local OWASP Juice Shop instance.
2. Ran an OWASP ZAP Automated Scan against `http://localhost:3000` .
3. Allowed ZAP to crawl and passively inspect HTTP responses.
4. Reviewed the Medium-risk alerts.
5. Opened the CSP alert and inspected the request/response evidence for each affected endpoint.
6. Confirmed no `Content-Security-Policy` header was present in any of the five affected responses.

Potential real-world impact

Without a CSP, the browser loses an additional layer of defense against Cross-Site Scripting (XSS) and data-injection attacks. CSP does not replace secure coding or output encoding, but its absence removes a control that can reduce the damage of a successful client-side injection.

Practical remediation

Configure the web/application server to send a tested `Content-Security-Policy` header on all responses, for example:

```
Content-Security-Policy: default-src 'self'; object-src 'none'; frame-ancestors 'self'; form-action 'self'
```

The policy should be tested against the application's required JavaScript, CSS, image, font, API, and third-party resources before deployment.

Finding 2 — Cross-Domain / CORS Misconfiguration

Severity: Medium
ZAP confidence: Medium
OWASP category: Broken Access Control — OWASP Top 10 2021 A01
CWE: CWE-264 | **WASC:** 14 | **ZAP Plugin ID:** 10098
Instances: 5 (systemic), including `/assets/public/favicon_js.ico` , `/polyfills.js` , `/robots.txt` , `/scripts.js` , `/styles.css`

What was found

ZAP identified a **Cross-Domain Misconfiguration** caused by an overly permissive CORS response. The evidence on every affected endpoint was the same wildcard header:

```
Access-Control-Allow-Origin: *
```

ZAP notes that this configuration permits cross-domain read requests from arbitrary third-party origins for unauthenticated resources, though browser protections still reduce risk for authenticated APIs.

Steps taken to find it

1. Ran the ZAP scan against `http://localhost:3000`.
2. Reviewed the Medium-risk findings.
3. Selected the Cross-Domain Misconfiguration alert.
4. Examined each of the five affected requests.
5. Inspected the response headers on each.
6. Confirmed the wildcard CORS policy (`Access-Control-Allow-Origin: *`) on every instance.

Potential real-world impact

An overly broad CORS policy can allow any third-party origin to read responses the application serves cross-origin. For applications with sensitive unauthenticated or weakly protected endpoints, this increases the risk of unauthorized data access — particularly where cross-origin access isn't actually required by the application's design.

Practical remediation

Replace the wildcard CORS policy with an allow-list of trusted origins, or remove CORS headers entirely where cross-origin access isn't needed:

```
Access-Control-Allow-Origin: https://trusted.example
```

Do not use `*` for endpoints serving sensitive or unauthenticated data.

Finding 3 — Unix Timestamp Disclosure

Severity: Low
ZAP confidence: Low
Category: Information Disclosure / Sensitive Data Exposure
CWE: CWE-497 | **WASC:** 13 | **ZAP Plugin ID:** 10096
Instances: 5 (systemic), on `/` and `/styles.css`

What was found

ZAP reported "**Timestamp Disclosure - Unix**" on five separate responses. The disclosed values and their decoded dates were:

Endpoint	Unix timestamp	Decoded date
<code>/</code>	1666666667	2022-10-25 07:57:47
<code>/</code>	1839622642	2028-04-18 03:17:22
<code>/styles.css</code>	1528301887	2018-06-06 21:18:07
<code>/styles.css</code>	1578947368	2020-01-14 01:29:28
<code>/styles.css</code>	1602209945	2020-10-09 07:19:05

Steps taken to find it

1. Ran the ZAP scan against the local Juice Shop target.
2. Reviewed the Low-risk findings.
3. Opened the Timestamp Disclosure alert.
4. Examined each affected request.
5. Inspected the response content and located each Unix timestamp.
6. Confirmed each value converts to a human-readable date.

Potential real-world impact

A single timestamp is normally low impact. However, note that one value (`1839622642` → 2028-04-18) post-dates the audit itself, indicating it is seeded sample/challenge data built into Juice Shop rather than a genuine server or build timestamp. In a real application, exposed timestamps can reveal deployment or modification history; if attackers collect many such values, they may infer application timelines or correlate them with other public data.

Practical remediation

Remove unnecessary timestamps from publicly served resources, and avoid exposing build/deployment metadata unless it's required. Where timestamps are necessary, review whether the value could reveal sensitive infrastructure details.

4. Informational Alert — Not Counted as a Vulnerability

Modern Web Application

ZAP also identified "**Modern Web Application**" as an informational alert. This is not treated as one of the security findings because ZAP explicitly classifies it as informational and states that no changes are required. It is therefore excluded from the vulnerability count.

5. Overall Risk Summary

Finding	ZAP Risk	Confidence	Category
CSP header not set	Medium	High	Security Misconfiguration
Cross-domain/CORS misconfiguration	Medium	Medium	Broken Access Control
Unix timestamp disclosure	Low	Low	Information Disclosure
Modern Web Application	Informational	Medium	Not a vulnerability

Total ZAP alert types: 4 Medium-risk alert types: 2 Low-risk alert types: 1 Informational alert types: 1 High-risk findings: 0

6. Limitations

This assessment is based on automated OWASP ZAP scanning of a locally hosted instance. Automated scanners do not prove an application is free of vulnerabilities, and this pass does not include:

- Manual testing of input fields for Cross-Site Scripting (XSS)
- Manual review of authentication/login error-message behavior
- Manual inspection of API responses via browser DevTools for exposed sensitive data

These are standard complements to automated scanning and represent natural next steps for a deeper audit of this target.

7. Evidence

The original ZAP scan output is stored at:

evidence/zap-report.html
evidence/zap-report.pdf

Key evidence visible in the report includes:

- Target: http://localhost:3000
- ZAP version: 2.17.0
- Scan generated: 21 September 2026, 19:07:33
- CSP Header Not Set alert, 5 instances
- Access-Control-Allow-Origin: * on 5 endpoints
- Unix timestamps disclosed on / and /styles.css
- Risk/confidence levels and affected endpoints per finding